

SIMATS ENGINEERING ASSESSMENT TOOL 3

Name	Abinesh M
Register Number	192465050
Date	05-07-2026
Time	1 Hour

COURSE NAME: Cybersecurity Incident Handling And Response
COURSE CODE: CSA6001

COURSE OUTCOME COVERED

CO2: *Analyze incident response preparation strategies through examination of team roles, policies, SOPs, risk management practices, along with compliance frameworks to ensure organizational readiness. (BL3, BL6)*

Activity Tool : Security Operations Workflow using SIEM and Ticketing System (Low)
Assessment Tool Weightage: 10%

Code of Conduct:

*I Abinesh M 192465050 certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student:

Abinesh M
192465050

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Security Operations Workflow Design	20%	Develops a complete and logical security operations workflow from SIEM alert generation to incident closure, clearly explaining all stages including monitoring, investigation, response, recovery, and documentation.	Develops a workflow covering most stages with only minor omissions or sequencing issues.	Describes only basic workflow steps with several missing or incomplete phases.	Fails to develop a coherent security operations workflow or omits major activities.
SIEM Alert Analysis and Ticket Management	25%	Accurately analyzes SIEM alerts, prioritizes incidents based on severity and business impact, effectively manages ticket creation, assignment, tracking, escalation, and closure using appropriate workflows.	Correctly analyzes most alerts and demonstrates good understanding of ticket management with minor omissions.	Demonstrates partial understanding of SIEM alerts and ticketing concepts with several missing or incorrect steps.	Shows little or no understanding of SIEM alert handling or ticket management processes.
Escalation, SOP, and Communication Process	20%	Develops a comprehensive SOP with clearly defined escalation levels, communication channels, stakeholder responsibilities, and incident handling procedures throughout the response lifecycle.	Includes appropriate SOP and escalation procedures with minor gaps in communication or stakeholder coordination.	Provides limited SOP or escalation process with insufficient communication planning.	SOP is incomplete, inaccurate, or lacks escalation and communication procedures.
Risk Assessment, Asset Criticality, BCP, and DRP	20%	Correctly identifies critical assets, performs comprehensive risk assessment, prioritizes incidents appropriately, and clearly explains Business Continuity Planning (BCP) and Disaster Recovery Planning (DRP) strategies with suitable recommendations.	Performs basic risk assessment and asset prioritization while explaining BCP/DRP with minor omissions.	Performs partial risk assessment with limited understanding of asset criticality, BCP, or DRP concepts.	Unable to identify risks, prioritize assets, or explain BCP and DRP strategies effectively.
Documentation, Reporting, and Professional Presentation	15%	Documentation is well-structured, professionally presented, includes appropriate ticket records, incident reports, workflow diagrams/tables, and communicates ideas clearly and logically.	Documentation is organized and complete with only minor formatting or clarity issues.	Documentation is partially organized with several missing details or presentation issues.	Documentation is poorly organized, incomplete, difficult to understand, or lacks professional presentation.

Cybersecurity Incident Handling and Response

CO2 AT3 REPORT

Student: Abinesh M

Register Number: 192465050

Course Code: CSA6001

Course Name: Cybersecurity Incident Handling and Response

Assessment: CO2 AT3

1. SIEM Alert Prioritization

Scenario

An organization's SIEM generates more than 8,000 security alerts every day, while the Security Operations Center (SOC) has only five analysts, making it impossible to investigate every alert immediately. As a SOC analyst, this section explains how to classify and prioritize SIEM alerts based on severity, business impact and asset criticality, how false positives can be identified, and how alert correlation can improve incident detection.

Overview

At a volume of 8,000 alerts a day, a five-person team cannot operate on a first-in-first-out basis without being permanently overwhelmed and missing genuine threats buried in noise. The only sustainable approach is a structured triage model that filters, scores and groups alerts before a human analyst ever looks at them, so that the limited investigative hours available are spent on the alerts most likely to represent real, high-impact activity.

This requires combining three inputs — technical severity, business impact, and asset criticality — into a single risk score, rather than relying on the SIEM's default severity label alone, which typically reflects only the technical signature of the event and ignores what the affected asset actually means to the organization.

Classifying and Prioritizing Alerts

Severity describes how dangerous the observed technique is in isolation, for example a confirmed malware execution versus a single failed login. Business impact describes the consequence if the alert is real, such as financial loss, regulatory exposure or service outage. Asset criticality describes how important the affected system is to core operations, such as a domain controller or payment gateway compared to a rarely used test machine. Multiplying or weighting these three factors produces a composite priority score that determines queue order far more accurately than severity alone.

- Tier 1 (Critical): high severity + high business impact + critical asset — investigate within minutes.
- Tier 2 (High): high severity on a moderately important asset, or moderate severity on a critical asset.
- Tier 3 (Medium): moderate severity, limited business impact — investigate within the shift.
- Tier 4 (Low): low severity, informational, or affecting non-critical, isolated systems.
- Maintain a living asset-criticality inventory so scoring reflects current business priorities.
- Re-score alerts dynamically if new context (e.g., a related alert) increases apparent impact.

Identifying False Positives

False positives consume the majority of analyst time in high-volume environments, so systematically reducing them is as important as prioritizing true positives correctly. False positives are typically identified through a mix of automated enrichment and pattern recognition applied before human review.

- Cross-check alert context against known-good baselines, such as scheduled admin scripts or approved scanning tools.
- Enrich alerts automatically with threat intelligence to confirm whether an IP or hash is genuinely malicious.
- Track historical resolution outcomes per rule; rules with a persistently high false-positive rate get tuned or retired.
- Use allow-lists for known benign but noisy behavior, reviewed periodically to avoid blind spots.
- Apply statistical baselining so alerts only fire on genuine deviation from normal user or system behavior.

Improving Detection Through Alert Correlation

Individually, many alerts look harmless: a failed login, an unusual outbound connection, a new scheduled task. Correlated together across a short time window and a common asset or identity, the same alerts can reveal a multi-stage attack chain that no single alert would expose. Correlation is what allows a five-analyst team to punch above its weight, because it converts thousands of low-confidence signals into a much smaller number of high-confidence incidents.

- Group alerts by common identifiers: user account, source IP, host, or destination asset.
- Map correlated alerts against a kill-chain or MITRE ATT&CK model to identify attack stage.
- Use SOAR playbooks to auto-correlate and auto-escalate multi-stage patterns without manual effort.
- Suppress duplicate or child alerts once a parent incident has been opened for the same root cause.
- Continuously refine correlation rules based on lessons learned from past incidents.

Aspect	Details
Benefit	Reduces analyst overload and shortens detection-to-response time for real threats.
Challenges	Alert fatigue, noisy rule sets and limited analyst headcount relative to alert volume.
Recommendation	Tune correlation rules continuously, tier alerts by risk score, and automate low-value triage.

2. Incident Escalation Process

Scenario

During normal working hours, a SIEM detects repeated failed login attempts followed by successful administrator access from an unknown country. As the Incident Response Team leader, this section explains how this incident should be escalated, identifies the personnel who should be notified, the communication channels to be used, the escalation levels, and the responsibilities of each stakeholder during the incident.

Overview

This pattern — a burst of failed logins immediately followed by a successful administrator authentication from an unfamiliar geography — is a textbook indicator of a successful brute-force or credential-stuffing attack against a privileged account. Because administrator access grants broad control over systems and data, this class of incident must be treated as high severity from the moment it is detected, and escalation must begin immediately rather than waiting for further confirmation.

The goal of the escalation process is to compress the time between detection and informed decision-making by getting the right people the right information through the right channel, without creating confusion, duplicated effort, or delay caused by ambiguous ownership.

Immediate Escalation Steps

- The SOC analyst who identifies the alert immediately opens a Tier 1 (Critical) incident ticket.
- The analyst performs rapid triage: confirm the login geography is genuinely anomalous for that account, and check for any subsequent privileged actions.
- The on-call Incident Response Team (IRT) leader is paged within minutes via the primary alerting channel.
- As a precautionary containment step, the affected administrator account is temporarily disabled or forced to re-authenticate with MFA, pending investigation.
- All actions and timestamps are logged from the first moment of detection to preserve an accurate incident timeline.

Personnel to Be Notified

- SOC Analyst (initial detector) — performs triage and opens the incident.
- Incident Response Team Leader — takes command of the response and coordinates all stakeholders.
- System/Domain Administrator responsible for the compromised account — assists with containment and validation.
- Chief Information Security Officer (CISO) — briefed immediately given the privileged-access nature of the incident.
- IT Operations Manager — coordinates any required system downtime or account resets.
- Legal/Compliance Officer — engaged if customer data or regulatory reporting obligations may be triggered.
- Public Relations/Communications lead — placed on standby if the incident may become externally visible.

Communication Channels

Channel selection matters as much as who is notified, because email alone is too slow for a Tier 1 incident and too easily missed outside working hours.

- Automated paging/on-call system (e.g., phone call or push alert) for the initial IRT leader notification.
- A dedicated, pre-established incident bridge call or secure chat channel for real-time coordination.

- Out-of-band communication (personal phone, separate messaging platform) if the attacker may have compromised primary email or chat systems.
- Formal written incident updates via the ticketing system for audit trail and later review.
- Executive briefing via a short, scheduled status call rather than ad hoc messages, to avoid misinformation.

Escalation Levels

- Level 1 — SOC Analyst: detects, triages, and performs initial containment within minutes.
- Level 2 — IRT Leader: assumes incident command, validates severity, coordinates response team.
- Level 3 — CISO / Senior Management: informed for critical incidents involving privileged access or potential data exposure.
- Level 4 — Executive/Legal/Regulatory: engaged if the incident meets breach-notification thresholds or affects customers.

Stakeholder Responsibilities

- SOC Analyst: initial detection, triage, evidence preservation, and first containment action.
- IRT Leader: overall incident command, decision-making authority, and coordination across teams.
- System Administrator: assists with account lockout, password reset, and validating what actions the compromised account performed.
- CISO: risk-based decision-making on containment scope, and liaison to executive leadership.
- Legal/Compliance: determines regulatory notification obligations and manages evidentiary requirements.
- Communications lead: prepares internal and, if necessary, external messaging to manage reputational impact.

Aspect	Details
Benefit	Ensures the right people act quickly, limiting attacker dwell time and business impact.
Challenges	Coordinating across time zones, avoiding notification fatigue, and confirming true positives fast.
Recommendation	Maintain a tested, on-call escalation matrix with clear ownership at every tier.